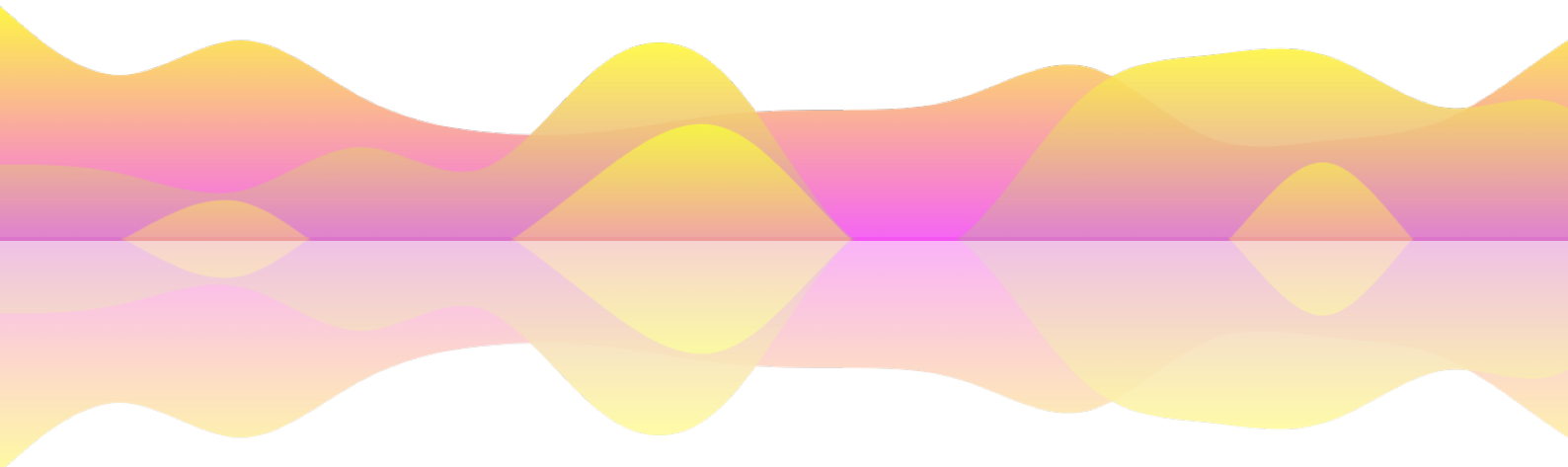


Indicators and Practices for Assessing Cybersecurity Awareness in Organisations: A Systematic Literature Review



Author(s): Sahala KALLAN MULLERI & Mohamed Ibrahim MOHAMED GANI

Main subject area: Computer Science

School: School of Engineering

Date: June 2026

This final thesis has been carried out at the School of Engineering at Jönköping University within Computer Science. The authors are responsible for the presented opinions, conclusions and results.

Examiner: Joakim KÄVRESTAD

Supervisor: Erik BERGSTRÖM

Scope: 15 Credits

Date: 2026-05-24

Indicators and Practices for Assessing Cybersecurity Awareness in Organisations: A Systematic Literature Review

Sahala Kallan Mulleri^{1,†}, Mohamed Ibrahim^{1,†}

¹*Jönköping University, School of Engineering, Computer Science and Informatics.*

Abstract

Cybersecurity awareness is increasingly recognised as a critical component of organisational security strategy. Despite its importance, there remains significant ambiguity regarding how organisations evaluate the effectiveness of CSA initiatives. This study presents a Systematic Literature Review (SLR) aimed at identifying the indicators, measurement approaches, and dimensions employed by organisations to assess cybersecurity awareness. The review follows a structured methodology based on PRISMA guidelines and includes studies from four academic databases: IEEE Xplore, Scopus, SpringerLink, and ACM Digital Library. Following the inclusion and exclusion process, 52 studies published between 2010 and 2026 were selected for in-depth analysis. The findings show that CSA is assessed using a diverse range of self-reported, knowledge-based, behavioural, and organisational indicators. Self-reported indicators derived through questionnaires and surveys appeared most frequently across the reviewed studies, while behavioural and organisational indicators such as phishing simulation outcomes, incident reporting, and training participation records appeared comparatively less often. The review further identified ten recurring CSA dimensions, with email use and phishing susceptibility, password management, and information handling receiving the greatest attention, whereas dimensions such as cloud service use and workstation security received comparatively limited attention. In addition, SME-focused CSA measurement research remains substantially underrepresented within the literature. This study contributes by providing a structured synthesis of current CSA measurement practices, identifying dominant assessment trends, and highlighting key research gaps within the existing literature.

Keywords

Cybersecurity Awareness, Information Security Awareness, Awareness Measurement, Key Performance Indicators (KPIs), Security Metrics, Organisational Security, Systematic Literature Review

1. Introduction

Cybersecurity awareness has become a central component of organisational security strategies. Many security incidents are linked not to technical vulnerabilities, but to human actions such as clicking on phishing links, mishandling sensitive information, or failing to follow established security procedures [1, 2]. As a result, organisations increasingly invest in awareness programs, training sessions, and internal campaigns aimed at improving employee security behaviour [3, 4]. However, security incidents continue to occur despite these investments, indicating that training and awareness efforts alone do not guarantee improved employee behaviour [2]. Even well-designed security controls can be undermined if employees ignore policies or fail to recognise threats, reinforcing the need for sustained awareness and behavioural alignment within organisations [1].

[†] Authors are listed in alphabetical order. The authors contributed equally.

As highlighted by Kruger and Kearney, the success of technical and procedural security mechanisms ultimately depends on how individuals understand and interact with them, reinforcing the importance of CSA initiatives in organisational security strategies [5]. Therefore, the effectiveness of CSA initiatives cannot be assumed solely based on the implementation of awareness programs, but must be continuously evaluated to determine whether they successfully reach employees and influence intended security-related behaviours [6]. Without proper evaluation, security awareness programs may struggle to identify areas requiring improvement, encourage secure practices, and adapt to evolving threats and organisational needs [4].

Despite the importance of CSA evaluation, a fundamental question remains: how is CSA actually measured? Research indicates that organisations frequently struggle with this measurement challenge [7, 8]. There is no common understanding of what factors to measure and how to measure them during the evaluation process [4]. Organisations frequently report indicators such as training completion rates or quiz scores to demonstrate overall program success and value to management, yet it is often unclear whether these indicators meaningfully reflect awareness or behavioural improvement [4, 9]. The lack of clarity around measurement creates inconsistency in both research and practice [9]. Furthermore, studies evaluating security knowledge, attitude, and behaviour tend to develop their own non-standardised measurements, making cross-study comparison difficult and limiting the accumulation of generalisable knowledge [4].

Existing research proposes various indicators, measurement approaches, and security dimensions for evaluating CSA [4, 10, 11]. Studies differ in what they treat as cybersecurity awareness, how they choose to measure it, and which indicators they consider meaningful for evaluating awareness effectiveness [4, 10]. In addition, the CSA dimensions addressed during awareness assessment, such as password management, email use, and incident reporting, vary considerably across studies, limiting comparability and methodological consistency [10]. Previous review studies have examined various aspects of CSA measurement, such as information security awareness scales and the dimensions addressed [10], as well as measurement approaches used to evaluate awareness initiatives [11]. However, there remains limited consolidated understanding regarding the overall CSA measurement practices employed across organisational contexts, particularly concerning the indicators, assessment approaches, and awareness dimensions examined within existing studies.

Furthermore, comparatively limited attention has been given to cybersecurity awareness measurement within small and medium-sized enterprises (SME) environments, despite SMEs frequently facing resource limitations, reduced cybersecurity maturity, and increasing exposure to cyber threats [12]. This creates additional uncertainty regarding the applicability of existing cybersecurity awareness measurement practices across different organisational contexts [3, 12]. Therefore, this study presents a systematic literature review (SLR) aimed at identifying and synthesising the indicators, measurement approaches, and cybersecurity awareness dimensions employed within existing CSA measurement research conducted across organisational contexts, focusing on the following research questions:

RQ1: What indicators are used by organisations to measure cybersecurity awareness?

RQ2: What measurement approaches are used by indicators for assessing cybersecurity awareness?

RQ3: What dimensions of CSA are measured in the literature?

RQ4: To what extent does the existing literature address CSA measurement in SME contexts, and what indicators are used?

Collectively, these research questions aim to provide a structured understanding of how cybersecurity awareness is currently assessed across organisational contexts by examining the indicators used, the approaches employed for assessment, the recurring awareness dimensions addressed, and the extent to which existing studies consider SME environments.

The remainder of this paper is structured as follows. Section 2 presents the background and theoretical foundation relevant to CSA and its measurement. Section 3 describes the methodology, including the search strategy, selection criteria, and data extraction approach. Section 4 presents the findings of the review, including the identified indicators, measurement approaches, cybersecurity awareness dimensions, and SME-related observations. Section 5 discusses the findings in relation to the research questions, existing literature, and identified research gaps. Section 6 concludes the review by summarising its main contributions and outlining directions for future research.

2. Background

2.1. Cybersecurity Awareness: Definitions, Dimensions, and Organisational Context

Cybersecurity awareness has become one of the most discussed topics in organisational security research, yet the concept itself is not uniformly defined across the literature [4, 13]. Two related but distinct terms appear frequently: cybersecurity awareness and information security awareness. ISA has historically covered a broader range of concerns, including data protection, confidentiality, integrity, and availability, rooted in information management and governance traditions [13]. Cybersecurity awareness, by contrast, emerged more recently and tends to focus on threats specific to digital and networked environments, such as phishing, malware, and social engineering [13].

In practice, the boundary between these two concepts has increasingly blurred [10]. Many studies use the terms interchangeably or treat them as overlapping constructs. For the purposes of this review, both are considered within scope, as they share measurement approaches, employ similar instruments, and address the same fundamental organisational challenge: ensuring that employees understand security risks and behave in ways that protect organisational assets.

CSA is commonly understood as the extent to which individuals recognise security threats and possess the knowledge necessary to adopt protective behaviours that support organisational security objectives [13]. A key distinction in the literature is the difference between awareness and behaviour. Awareness refers to knowledge or understanding, while secure behaviour refers to observable actions such as reporting phishing emails, following password policies, or complying with organisational procedures [2, 4]. Several studies argue that awareness initiatives aim not only to inform employees, but to bring about lasting behavioural change [2, 4]. CSA measurement research has also identified recurring security-related areas that are consistently addressed across studies [10]. In this review, these areas are referred to as CSA dimensions, such as password management, email use, incident reporting, and information handling. Taken together, CSA dimensions represent the specific security behaviours and knowledge areas through which organisations measure employee awareness, reflecting how individuals recognise, understand, and respond to security-related risks across different operational contexts [14, 10].

Recent research increasingly conceptualises CSA as part of a broader organisational culture [15, 16]. Rather than viewing employees as the weakest link, contemporary perspectives emphasise

them as active contributors to organisational security culture [1]. From this perspective, awareness is embedded within broader organisational practices, leadership commitment, and communication patterns [1].

2.2. Key Measurement Terms and Definitions

The literature on cybersecurity awareness measurement uses a range of related terms, including indicators, metrics, KPIs, measurement instruments, and practices [4, 10]. These terms are not always applied consistently, and different studies frequently use them interchangeably or without clear definitions [4, 10]. To avoid that same ambiguity, this review defines each term clearly and applies them consistently throughout.

An indicator is a measurable variable that provides evidence of progress toward a specific objective [17]. A metric is a quantified and operationalised form of an indicator, typically expressed numerically and capable of being reproduced consistently [4, 17]. A Key Performance Indicator (KPI) goes further: it is a metric that has been formally designated as strategically important within an organisation, with defined targets, thresholds, and accountability structures attached to it [17]. A measurement instrument is the tool or method used to collect measurement data, such as the HAIS-Q questionnaire or a phishing simulation platform [18, 19, 20]. Practice, in this context, refers to the broader activity of measuring awareness, encompassing how measurement is designed, administered, and interpreted, including decisions around what to measure, how often, and what actions follow from the results [4].

For consistency, this review uses the term indicators to refer collectively to all measurable variables reported across the included studies, regardless of how individual studies label them [4, 10]. If a paper refers to something as a measure, a metric, or a KPI, it is treated here as an indicator. Where studies explicitly designate a measure as a KPI, with formal targets and accountability structures, this is noted specifically [17].

Structured conceptual frameworks have been developed to operationalise awareness measurement in practice, with many questionnaire-based studies drawing on the Knowledge–Attitude–Behaviour (KAB) model.[4, 21, 22].

2.3. Cybersecurity Awareness Measurement in SME Contexts

Small and medium-sized enterprises (SMEs) face distinct challenges when it comes to measuring cybersecurity awareness [17, 23]. Resource constraints and limited structural maturity mean that SMEs are less likely to run formalised measurement programs or track formal indicators consistently [17]. Performance measurement systems in SME contexts tend to be less structured overall compared to larger organisations, and cybersecurity awareness is no exception [17].

This matters because SMEs are not a low-priority group from a security standpoint. They are increasingly targeted by cyber threats and account for a substantial share of the business landscape in most economies [23, 24]. Yet the tools and instruments most commonly used to measure awareness, including the HAIS-Q and formal phishing simulation platforms, assume a level of organisational capacity that many SMEs simply do not have [23]. Most studies in this area have been conducted in larger organisations, government agencies, or healthcare institutions with the resources to support structured measurement programs [17, 23].

3. Methodology

3.1. Research Design

This study is conducted as a Systematic Literature Review (SLR). The SLR approach is chosen because it provides a structured, transparent, and reproducible process for identifying, selecting, and synthesising relevant primary studies - making it particularly suited to research questions that seek to consolidate fragmented evidence across multiple studies [25, 26]. Unlike narrative reviews, an SLR follows a pre-defined protocol that minimises selection bias and ensures that the review process can be independently replicated and verified [25].

To further enhance the transparency and methodological rigour of the review process, this study follows the Preferred Reporting Items for Systematic Reviews and Meta-Analyses (PRISMA) guidelines [27]. PRISMA is an evidence-based reporting guideline designed to help researchers clearly document what was done and why at each stage of a systematic review. The overall review process consists of several stages, including the development of a search strategy, the application of inclusion and exclusion criteria, study selection, and data extraction and analysis. These stages are described in detail in the following sections.

3.2. Search Strategy

The literature search was conducted across four major academic databases: IEEE Xplore, Scopus, SpringerLink, and the ACM Digital Library. The use of multiple databases is recommended in systematic literature reviews to ensure comprehensive coverage and to minimise the risk of missing relevant studies [25, 26]. These databases were selected to provide broad interdisciplinary coverage of research in cybersecurity, information systems, and organisational studies. In combination, they offer access to both technical and socio-organisational research relevant to cybersecurity awareness and its measurement.

To identify relevant studies, a structured search string was developed based on the key concepts of the research questions, namely cybersecurity awareness and its measurement. The following search string was applied across all databases:

("cybersecurity awareness" OR "information security awareness" OR "security awareness" OR "security culture") AND (indicator* OR metric* OR measure* OR evaluation OR KPI*)

The search string was developed in accordance with established guidelines for constructing systematic review search strategies [25, 26]. It consists of two components connected by the Boolean operator AND, which ensures that retrieved studies address both the subject domain and the measurement focus of this review.

The first component captures the core topic using four alternative terms connected by the Boolean operator OR. The terms "cybersecurity awareness" and "information security awareness" directly reflect the primary constructs of this review. "Security awareness" was included as a broader variant that appears frequently across both technical and organisational literature. "Security culture" was included because it is a closely related construct that is commonly measured using awareness-level indicators in organisational research, and excluding it would risk omitting relevant studies that address awareness

through a cultural lens [10, 13]. Quotation marks were applied to multi-word phrases to ensure exact phrase matching across databases.

The second component targets the measurement dimension of the research questions using terms covering indicators, metrics, measures, evaluations, and key performance indicators (KPIs). Truncation operators (indicated by the asterisk symbol) were applied to the terms indicator*, metric*, and measure* to capture all relevant word forms and endings, such as "indicators," "metrics," and "measurement" - without requiring separate entries for each variant [25]. This approach maximises recall while maintaining relevance to the research questions.

The initial search was conducted in February 2026 across the selected databases. Where supported by the database interface, filters were applied to include peer-reviewed journal articles and conference papers, using the closest equivalent document type categories available in each database. As the initial search for SpringerLink returned a relatively large number of records (3,347), additional subject area filters were applied exclusively within this database to restrict the results to domains relevant to this study, including data and information security, IT security awareness, and cybersecurity awareness and behavioural compliance.

Following the application of these filters and the execution of the search across all selected databases, the search yielded a total of 4,510 records prior to duplicate removal and screening. The distribution of results across databases was as follows: IEEE Xplore (642), Scopus (1,238), SpringerLink (1,734), and ACM Digital Library (896).

3.3. Study Selection

All records retrieved from the four databases were exported and uploaded to Rayyan¹, a web-based collaborative systematic review management platform designed to support systematic, transparent, and efficient study screening. Duplicate entries were identified and removed within the platform, resulting in 3,754 unique records for subsequent screening.

The screening process proceeded in two sequential stages, guided by the predefined inclusion and exclusion criteria presented in Table 1. In the first stage, all 3,754 records were screened at the title and abstract level to assess their relevance to cybersecurity or information security awareness measurement within organisations, as well as their compliance with basic eligibility criteria relating to publication language and year. Studies that did not meet the criteria were excluded, and 210 studies advanced to full-text review.

In the second stage, full texts of all 210 studies were retrieved and assessed against the inclusion and exclusion criteria. This stage involved evaluating whether studies explicitly addressed the measurement of cybersecurity or information security awareness using any measurable indicators or empirical approaches. Studies were excluded if they did not include any measurement of awareness, focused solely on technical controls, frameworks or adjacent topics, addressed cybersecurity culture broadly without explicitly measuring awareness, or proposed indicators and metrics theoretically without empirical application. Studies for which full-text access could not be obtained were also excluded at this stage. Following full-text assessment, 52 studies were confirmed as meeting all inclusion criteria and 158 were excluded. The complete selection process is illustrated in Figure 1.

¹Rayyan is available at <https://www.rayyan.ai>

Table 1
Inclusion and Exclusion Criteria

Inclusion Criteria	Exclusion Criteria
Peer-reviewed journal articles or conference papers	Studies focusing solely on technical cybersecurity mechanisms without awareness measurement
Articles available in English	Studies conducted in non-organisational contexts (e.g., primary/secondary education settings or General users)
Studies published between 2010 and 2026	Opinion pieces, editorials, or non-research commentary
Studies conducted within an organisational context (private, public, government, healthcare, etc.)	Studies proposing frameworks or tools without actually applying or measuring awareness
Studies that explicitly measure cybersecurity or information security awareness using any measurable indicators	Studies that do not describe how cybersecurity or information security awareness was measured and from which no identifiable indicators can be extracted.
Studies that report how cybersecurity or information security awareness is assessed or evaluated within organisations.	Studies for which the full text was not accessible or could not be obtained.

Screening decisions were reviewed collaboratively throughout both screening stages to improve consistency in the application of the inclusion and exclusion criteria. The review platform enabled transparent visibility of screening decisions, allowing studies involving uncertainty or conflicting assessments to be jointly reviewed and discussed against the predefined selection criteria until consensus was reached.

3.4. Data Extraction and Analysis

For each included study, relevant information was systematically extracted using a structured data extraction form developed in accordance with the research questions [25, 26]. The extracted information included bibliographic details (title, authors, publication year, and source), the measurement framework or instrument used, the identified indicators and measurement approaches, and the CSA dimensions addressed.

The extracted data were analysed using thematic categorisation, a method for systematically identifying and organising patterns across data into analytically meaningful groups [28]. Identified indicators and measurement approaches were grouped based on their assessment focus and measurement characteristics to identify recurring practices and common patterns across the literature. The categorisation process was primarily inductive, with categories iteratively refined through repeated review and comparative analysis of the extracted data rather than guided by a predefined classification framework. In addition, the distribution of identified indicators, approaches, and CSA dimensions across studies was examined to identify dominant areas of focus and underrepresented aspects within the existing literature.

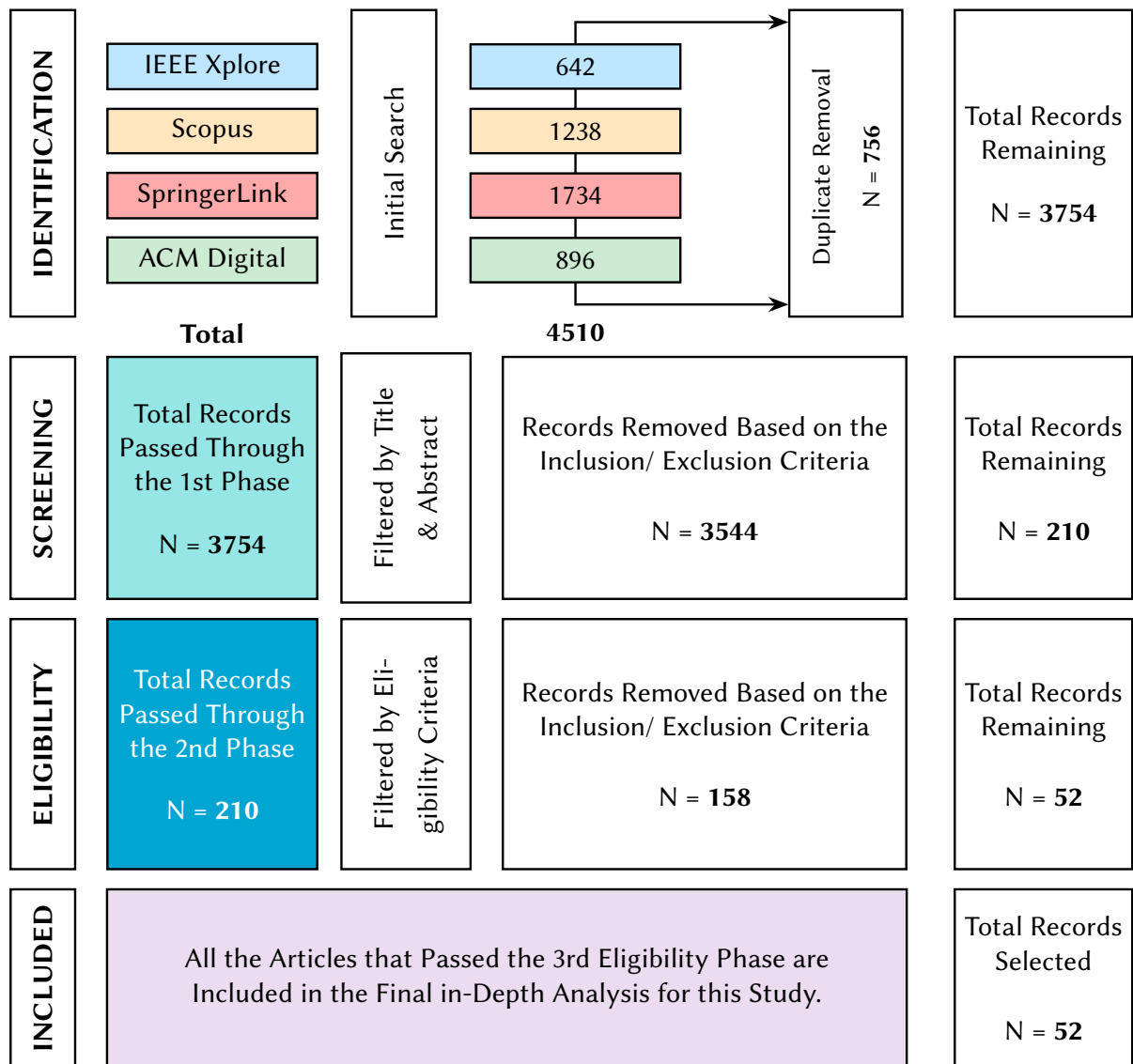


Figure 1: PRISMA flow diagram for study selection process

4. Results

This section presents the findings of the systematic literature review based on the analysis of 52 included studies. Table A1 provides a summary of the studies included in the review, outlining the measurement frameworks or tools and data collection methods used across the literature. The entire section is structured in accordance with the research questions, addressing the indicators used to measure CSA, the measurement approaches employed for assessment, the CSA dimensions identified across the studies, and the extent to which CSA measurement has been addressed within SME contexts.

4.1. RQ1: What Indicators Are Used to Measure Cybersecurity Awareness?

To address the first research question, the indicators reported across the 52 included studies were systematically extracted and organised through thematic categorisation [28]. This process grouped indicators based on their underlying measurement logic, reflecting both what they capture and the nature of the measurement outcomes they produce. The result is four analytically distinct categories: self-reported, knowledge-based, behavioural, and organisational-based indicators. These categories are presented in Table 2, along with representative indicators and the studies in which they are reported.

An important distinction underpins this categorisation. Although self-reported and knowledge-based indicators are both commonly collected at the individual level through questionnaires or structured surveys, they differ fundamentally in how responses are interpreted. Knowledge-based indicators evaluate responses against objectively correct or incorrect answers, and the resulting scores reflect evidence of actual knowledge. In contrast, self-reported indicators rely on Likert-scale or similarly structured responses through which participants express their perceptions of their knowledge, attitudes, and behaviours, from which awareness scores are derived. Observed behavioural indicators differ from both by capturing employees' actual security-related actions through direct or simulated evidence. Finally, organisational-based indicators reflect awareness at a broader level by measuring organisational processes and outcomes, thereby providing insight into the overall security posture.

The distribution of indicators across the reviewed studies reveals a clear emphasis on self-reported measures (Table 2), which represent the most frequently identified category across the included studies. Indicators within this category include knowledge scores, attitude scores, self-reported behavioural scores, security policy awareness scores, and composite awareness scores, all measured through Likert-scale instruments. To illustrate how these indicators are captured in practice, Putra et al. [14] demonstrate their application within the context of email use. Employees are asked whether clicking links from unknown email senders is allowed (knowledge), whether such actions are considered risky (attitude), and whether they engage in such behaviour (behaviour). Each item is rated on a five-point Likert scale ranging from "strongly disagree" to "strongly agree", and the responses are aggregated to produce separate knowledge, attitude, and behavioural scores.

Knowledge-based indicators identified across the included studies include quiz scores, post-training test scores, knowledge retention rates, and scenario-based assessment scores. Compared to self-reported indicators, knowledge-based indicators appeared less frequently across the reviewed studies. Several studies assess awareness through structured tasks in which employees evaluate security-related situations or determine whether specific behaviours are secure or insecure [23, 24, 63, 64, 65]. For example, Mayer et al. [63] employed a password rating assessment, while Georgiadou et al. [65] used a phishing identification quiz in which employees were required to distinguish between legitimate and phishing emails.

Behavioural indicators were identified in eleven studies, capturing employees' actual security-related actions through simulations or system log data. Core indicators in this category include phishing click rate, credential submission rate, phishing reporting rate, and repeat failure rate (Table 2). Organisational-based indicators identified across the included studies include training completion rates, session attendance rates, e-learning registration rates, awareness programme participation rates, incident logbook records, and audit report indicators. These indicators reflect the implementation and reach of awareness initiatives at the organisational level, rather than directly measuring individual awareness outcomes [6, 45, 55, 7, 60, 62, 66].

Table 2
Thematic Categorisation of Measurable Indicators

Category	Key Indicators/Metrics	Studies
Self-Reported Indicators	Knowledge scores, attitude scores, Self-reported behavioural scores, self-reported policy compliance behaviour, security policy awareness, composite awareness score, survey-based measures	[6, 18, 19, 20, 21, 22, 14, 29, 30, 31, 32, 33, 34, 35, 36, 37, 38, 39, 40, 41, 42, 43, 44, 45, 46, 47, 48, 49, 50, 51, 52, 53, 54, 55, 56, 7, 57, 58, 59, 60, 61]
Knowledge-Based Indicators	Quiz scores, post-training test scores, Scenario-based assessment scores, security skill evaluation score, knowledge retention rate, password security rating, Phishing quiz scores	[23, 24, 55, 62, 63, 64, 65]
Behavioural Indicators	Phishing click rate, credential submission rate, employee reporting simulated phishing, employee reporting actual phishing, repeat failure rate, incident reporting rate, policy compliance rate, general observation, employees causing security incidents, security incident trends, audit-based incident indicators, risk-based incident indicators	[6, 32, 49, 52, 55, 7, 60, 62, 66, 67, 68]
Organisational-Based Indicators	Training completion rate, training engagement (time spent), frequency of training, session attendance rate, e-learning registrations rate, awareness program participation rate, antivirus/firewall report indicator, incident logbook records, audit report indicators, Security culture assessment score, organisational security posture indicators	[6, 45, 55, 7, 60, 62, 66]

A broader view of indicator usage is reflected in the study by Jacobs et al. [7], which examines how organisations measure the effectiveness of security awareness programmes in practice. The findings indicate variation in organisational measurement practices, with some organisations relying on multiple indicators, while others employ only limited or no formal measurement. Commonly used indicators include training completion rates and audit reports as measures of compliance, phishing simulation metrics such as click and reporting rates, as well as behavioural indicators such as incident reporting and user-caused security incidents. In addition, some organisations incorporate employee feedback and participation metrics, such as attendance at awareness activities, to assess programme reach and perceived effectiveness [7].

Taken together, these findings highlight that CSA is measured using a diverse set of indicators spanning individual, behavioural, and organisational levels. Overall, CSA measurement across the reviewed studies relies predominantly on employees' self-assessment of their security knowledge, attitudes, and behaviours, while comparatively fewer studies incorporate indicators based on observed behaviour or organisational outcomes.

4.2. RQ2: What measurement approaches are used by indicators for assessing CSA?

The measurement approaches identified across the included studies were extracted and categorised according to the methods used to assess CSA. Table 3 presents the identified approaches and the studies in which they were applied.

Table 3
Measurement Approaches Used Across Included Studies

Measurement Approach	Studies
Questionnaire/Survey	[6, 18, 19, 20, 21, 22, 23, 24, 14, 29, 30, 31, 32, 33, 34, 35, 36, 37, 38, 39, 41, 42, 43, 44, 45, 46, 47, 48, 50, 51, 52, 53, 54, 56, 57, 58, 59, 60, 61, 62, 63, 64, 65, 68, 69, 70]
Phishing Simulation	[66, 67]
Questionnaire + Phishing Simulation	[32, 49, 52, 55]
Observation and Incident Log Analysis	[6, 31, 60, 62]
Program Participation and Training Records	[6, 55, 62, 66]
Mixed methods	[7]

As shown in Table 3, questionnaire or survey-based methods are the most frequently employed approaches across the included studies, appearing either as standalone methods or in combination with other approaches. These methods involve the use of structured instruments to collect responses directly from participants and are applied to both self-reported and knowledge-based indicators. The dominant instrument within this approach is the HAIS-Q, a questionnaire based on the KAB model, which measures employee awareness across seven focus areas - including password management, email use, internet use, social media use, mobile devices, information handling, and incident reporting - through Likert-scale [18, 19, 21, 22, 14, 29, 30, 32, 34, 35, 36, 38, 39, 47, 51, 52, 53, 57, 58, 59, 61, 70]. Responses are typically aggregated to generate separate knowledge, attitude, and behaviour scores for each security focus area, which are also combined into an overall awareness score. A smaller number of studies employed the KAB model with custom focus areas and organisation-specific items [31, 33], while other studies used general surveys without referencing to any named framework [20, 37, 40, 41, 43, 44, 45, 46, 50, 54, 56, 68, 69].

In addition to survey-based approaches, two studies employ simulated phishing campaigns to capture behavioural responses in controlled environments [66, 67]. A commonly observed combination involves the integration of a questionnaire-based approach with phishing simulations, enabling the collection of both self-reported or knowledge-based indicators and observed behavioural indicators within the same study [32, 49, 52, 55]. Beyond these approaches, several studies rely on organisational data sources. These include observation and incident log analysis, where awareness is inferred from recorded security incidents, audit reports, and behavioural traces, as well as program participation and training records, which capture engagement through indicators such as training completion and attendance [6, 31, 55, 60, 62, 66].

Jacobs et al. [7] classified under mixed methods, differs from the other included studies in that it does not apply a single measurement approach; instead, it documents the range of approaches used by U.S. Government organisations, including questionnaires, phishing simulations, incident records, training records, and observational data. Across the included studies, questionnaire- and survey-based

methods are the dominant measurement approach for assessing CSA. In contrast, phishing simulation, observation, incident log analysis, and programme participation records are less frequent, either as standalone approaches or in combination with survey-based methods.

4.3. RQ3: What dimensions of CSA are measured in the literature?

Following the analysis of the indicators used in CSA measurement and the approaches employed to assess them, the CSA dimensions addressed across the reviewed studies were analysed to provide a broader understanding of CSA measurement practices. Since the studies used varying terminologies, scopes, and levels of categorisation, conceptually similar security areas were consolidated into broader CSA dimensions that recurred across the literature to enable consistent synthesis and comparison between studies. The analysis identified ten CSA dimensions across the reviewed studies, including password management, email use and phishing susceptibility, internet use, social media use, information handling, incident reporting, mobile device use, workstation security, use of cloud services, and security policy awareness and training participation. The identified dimensions are briefly described below.

1. **Password management:** This dimension addresses how employees create, protect, and store passwords for organisational systems and accounts. It covers awareness of what constitutes a strong password, understanding of why password policies and multi-factor authentication practices exist and should be followed, and self-reported password behaviours such as changing passwords regularly, using unique passwords for different accounts, and refraining from sharing credentials with colleagues even when asked.
2. **Email use and phishing susceptibility:** This dimension covers how employees interact with email in the workplace, specifically their ability to recognise suspicious communications, exercise caution with attachments and embedded links, and respond appropriately to social engineering attempts delivered through email. It encompasses awareness of what constitutes a safe or unsafe email, the belief that email-based threats are a genuine personal risk, and email-related behaviours such as clicking links from unknown senders, opening unexpected attachments, using official office email for non-service purposes, forwarding emails, or reporting suspicious messages to the IT or security team.
3. **Internet use:** This dimension focuses on how employees use internet resources within organisational environments, including the websites they access using work devices, downloading of files from external sources, and submission of work-related or personal information to third-party websites. It encompasses awareness of organisational internet usage policies, understanding of the security risks associated with unrestricted or unsafe browsing practices on organisational systems, distinguishing between HTTP and HTTPS, and self-reported online behaviours that reflect adherence to work-appropriate and policy-compliant internet use.
4. **Social media use:** This dimension concerns how employees engage with social media platforms in ways that may affect organisational security. It covers awareness of the risks associated with sharing work-related information, including organisational names, internal processes, personnel, or system-related details, on social media platforms. It also includes understanding the boundary between personal and professional digital presence, as well as whether employees actively manage privacy settings and exercise caution regarding the content they post in relation to their employer.

5. **Information handling:** This dimension covers how employees manage sensitive, confidential, or personal data encountered in their work. It includes physical and digital dimensions, awareness of how data should be classified and protected, understanding of obligations related to data privacy and confidentiality, the use of removable media for data-handling purposes, knowledge related to data backup, and behaviours such as not leaving sensitive printouts unattended and disposing of confidential material appropriately.
6. **Incident reporting:** This dimension assesses whether employees recognise and report security incidents or suspicious activities within the organisation. It covers awareness of what constitutes a reportable security incident and knowledge of the appropriate organisational channels or personnel responsible for receiving such reports. It also includes understanding that reporting security incidents is an individual responsibility, as well as observable behaviours related to reporting, rather than ignoring or concealing, suspicious activities or security incidents. In several studies, this dimension was additionally assessed through behavioural observations and organisational records, including recorded incident logs and security monitoring data.
7. **Mobile device use:** This dimension addresses the security practices and risks associated with the use of mobile and personal devices for work-related activities. It encompasses awareness of the risks involved in accessing organisational resources through unsecured or public networks, storing sensitive work-related information on personal mobile devices, exposing confidential information in public environments, and protecting devices and sensitive information from shoulder surfing. It also includes understanding secure mobile device practices and behaviours such as securing devices with PINs or passwords, safely accessing work emails and files through mobile devices and maintaining appropriate security settings on mobile devices.
8. **Workstation security:** This dimension covers the secure use and maintenance of organisational workstations and systems. It includes awareness of the importance of protecting work devices and maintaining endpoint security, as well as behaviours such as locking workstations when not in use, logging out from secure systems after use, installing and updating antivirus software and firewalls, verifying software and operating system updates, avoiding the installation of unauthorised software, and allowing antivirus software to scan or retrieve potentially malicious files from websites.
9. **Use of cloud services:** This dimension addresses employees' secure use of cloud-based storage and service platforms for organisational activities. It covers awareness of the risks associated with storing sensitive information on cloud platforms, reviewing file access permissions, and encrypting files containing sensitive information before uploading them to cloud storage services.
10. **Security policy awareness and training participation:** This dimension covers employees' awareness of the importance of organisational information security policies and their understanding of the need to adhere to established security rules, procedures, and guidelines. It also includes awareness of organisational cybersecurity training initiatives and observable behaviours related to participation in awareness programs, completion of mandatory security training activities, and compliance with organisational security practices.

Furthermore, the frequency with which the identified CSA dimensions appeared across the included studies was analysed to better understand the most commonly addressed areas related to cybersecurity awareness. In addition, the underlying constructs measured within each dimension were examined, including knowledge, attitude, self-reported behaviour, observed behaviour, compliance

and delivery of Awareness Initiatives. Table 4 presents the identified dimensions, their frequency of occurrence in the reviewed studies, and the commonly assessed underlying constructs associated with each dimension.

The findings indicate that not all dimensions received equal attention within the reviewed literature. Email Use and Phishing Susceptibility was the most frequently measured CSA dimension across the reviewed studies, followed by Password Management and Incident Reporting. Furthermore, the underlying constructs most commonly measured across the identified dimensions were knowledge, attitude, and self-reported behaviour, indicating a strong reliance on questionnaire- and survey-based assessment approaches and self-reported indicators, as discussed in the earlier sections.

Table 4
Frequency of Identified CSA Dimensions and Underlying Constructs Measured

CSA Dimension	Freq.	Underlying Constructs Measured
Password Management	35	Knowledge, Attitude, Self-reported Behaviour
Email Use and Phishing Susceptibility	40	Knowledge, Attitude, Self-reported Behaviour, Observed Behaviour
Internet Use	27	Knowledge, Attitude, Self-reported Behaviour
Incident Reporting	30	Knowledge, Attitude, Self-reported Behaviour, Observed Behaviour
Social Media Use	24	Knowledge, Attitude, Self-reported Behaviour
Mobile Device Use	24	Knowledge, Attitude, Self-reported Behaviour
Security Policy Awareness and Training Participation	16	Knowledge, Attitude, Compliance, Delivery of Awareness Initiatives
Workstation Security	14	Knowledge, Attitude, Self-reported Behaviour
Use of Cloud Services	1	Knowledge, Attitude, Self-reported Behaviour
Information Handling	35	Knowledge, Attitude, Self-reported Behaviour

4.4. RQ4: To what extent does the existing literature address CSA Measurement in SME Contexts, and what indicators are used?

To answer this research question, we reviewed each included study to identify the organisational context in which the study was actually conducted. The findings of this review indicate that CSA measurement within SME contexts remains substantially underrepresented in the existing literature. Among the 52 studies included in the final review, only five studies explicitly focused on Small and Medium-sized Enterprises (SMEs), Micro, Small, and Medium-sized Enterprises (MSMEs), or small organisational environments when assessing CSA. These studies are Ibrahim et al. [23], Alluhayb et al. [24], Mayer et al. [63], Oroni and Xianping [69], and Manifavas et al. [6]. The remaining 47 studies were conducted in large organisations, predominantly government agencies, banks, and hospitals, or did not specify the size of the host organisation, or represented general studies investigating CSA within the broader workforce.

Ibrahim et al. [23] and Alluhayb et al. [24] measured CSA in MSME contexts using cyber hygiene-based surveys. Both studies assessed CSA across five core domains: social engineering,

passwords and authentication, backups, updates, and privacy. Ibrahim et al. [23] proposed the Cyber Hygiene Awareness Rating Metric (CHARM), a structured scoring framework designed for MSMEs. The framework uses a simple survey-based assessment to calculate the CHARM score of an MSME without requiring technical expertise or calculations. For example, the knowledge of backup elements consists of four yes/no items, including automated backup use, secure storage, frequent restoration testing, and basic backup training, with points assigned to each item. Based on the total score obtained across the assessment domains, the level of CSA can be determined at both the individual and organisational levels. The framework also provides a deployment process for MSMEs involving awareness assessment, gap identification, and continuous evaluation. In contrast, Alluhayb et al. [24] applied a behavioural survey approach using multiple-choice and scenario-based questions to assess how CSA translates into real-world security practices within Saudi MSMEs.

Manifavas et al. [6] proposed the Dynamic Security Awareness Program Evaluation (DSAPE), a software-based tool designed to continuously evaluate organisational security awareness programs and suitable for deployment in small and medium-sized organisations. Rather than measuring cybersecurity awareness through a single questionnaire or behavioural survey, the DSAPE evaluates organisational awareness using 12 awareness-related modules and 18 quantitative metrics. The indicators used in DSAPE include survey performance, attendance in awareness sessions and security days, independent observation, audit and risk reports, security incidents.

Mayer et al. [63] developed password security awareness-raising material, and awareness was evaluated among employees from three SMEs in Germany. The study measured CSA using scenario-based behavioural assessment and password security rating tasks administered through pre-treatment, post-treatment, and retention questionnaires. The indicators used in the study included pre- and post-assessment scores and knowledge retention after six months. Oroni and Xianping [69] examined cybersecurity awareness in 33 small and medium-sized manufacturing enterprises (SMMs) in Kenya using a survey-based quantitative assessment approach. The study measured CSA as an organisational construct using four indicators: understanding of managerial cybersecurity policies and activities, cybersecurity knowledge, awareness of risks and security policies, and cybersecurity compliance. In terms of the response format, all indicators within the questionnaire utilised a five-point Likert scale, from which CSA score was derived.

5. Discussion

The findings of this review reveal how CSA is currently measured within organisational research. Across the included studies, CSA was assessed using a wide range of indicators, measurement approaches, and awareness dimensions. However, several recurring trends were identified, particularly regarding the dominance of questionnaire-based assessment approaches, the widespread use of self-reported indicators, and the comparatively limited focus on behavioural and organisational indicators. The review also identified variation in the CSA dimensions addressed across the literature, indicating that not all awareness dimensions have received equal attention within existing CSA measurement research. In addition, SME-focused studies remain comparatively underrepresented within the literature.

One of the most consistent findings across the reviewed studies is the dominance of self-reported measurement through questionnaire-based instruments, particularly the KAB model operationalised via HAIS-Q. One possible explanation for the widespread adoption of these approaches is their ability

to assess CSA across multiple organisational security areas within a single and scalable assessment structure [19]. The continued use may also reflect their practical suitability for organisational environments, as questionnaire-based approaches are comparatively easier to administer across large employee populations. The prevalence of HAIS-Q is not without justification, as the instrument has been validated across multiple studies and populations [18, 19, 29], and its structured focus areas provide a reproducible framework for comparing awareness across individuals and over time.

At the same time, the findings indicate a strong reliance on self-reported assessment as a standalone measurement approach. Approximately 62% of the included studies relied exclusively on self-reported indicators without incorporating complementary behavioural, knowledge-based, or organisational indicators. Nevertheless, the predominance of self-reported assessment also introduces important limitations. Fertig and Schütz [11] reported that approximately 40% of ISA questionnaires identified in the literature are based on the KAB model, while also noting that questionnaire responses may differ from actual behaviour due to incorrect self-perception and social desirability bias, where respondents present themselves more favourably than their actual behaviour warrants [71]. Wash, Rader, and Fennell [72] similarly demonstrated that self-reported security behaviours show only weak agreement with logged behavioural data for several common security tasks. These findings suggest that self-reported awareness scores may not always reliably reflect how employees behave in real security situations. While self-reported indicators remain valuable for identifying perceived knowledge gaps and shaping awareness initiatives, relying on them as standalone evidence of CSA effectiveness may provide only a partial understanding of employees' actual security behaviour [11, 29].

Phishing simulations represent the primary approach through which the reviewed studies collected behavioural evidence of CSA, with indicators such as click rates, credential submission rates, and phishing reporting rates providing observable action-based measures that self-reported indicators cannot directly capture. Several of the reviewed studies combined phishing simulations with questionnaire-based assessment approaches, reflecting the use of complementary measurement strategies within CSA research [32, 49, 52, 55]. However, the findings also suggest that phishing simulation outcomes may be influenced by factors related to awareness programme design and implementation [66]. For example, a long-term field study involving more than 14,000 employees found that phishing training delivered through embedded simulations did not necessarily improve employees' resilience to phishing attacks and, in some cases, could increase susceptibility to phishing attempts [73]. This suggests that behavioural indicators derived from phishing simulations should also be interpreted alongside other assessment approaches when evaluating CSA [74].

Beyond the limitations associated with quantitative assessment approaches, the reviewed literature also showed a near-absence of qualitative measurement in CSA research. Qualitative approaches, including user feedback, independent observation, and silent monitoring of employee reactions, are capable of capturing whether employees genuinely exercise security awareness in practice, rather than simply reporting that they do [6]. Such approaches can provide additional insight into how employees understand and demonstrate CSA practices beyond structured quantitative assessment. The limited use of qualitative methods suggests that existing CSA measurement research remains largely focused on measurable quantitative outcomes, with comparatively less attention given to the contextual and experiential aspects of CSA.

The study by Jacobs et al. [7], which examined how CSA effectiveness is measured within U.S. government organisations, reported that 64% of organisations used at least five different indicators of

effectiveness simultaneously, while only 4% relied on a single measure or did not measure effectiveness at all. The study further showed that organisations used a combination of indicators, including security incident trends, phishing simulation outcomes, employee incident reporting, training completion rates, and employee feedback, to assess cybersecurity awareness programmes. In addition, qualitative sources such as informal employee feedback and open-ended survey responses were found to complement quantitative measures by providing contextual insight into workforce attitudes and the perceived relevance of awareness initiatives. The broader implication is that no single measurement approach is sufficient on its own. A more comprehensive understanding of CSA requires the combination of self-reported, behavioural, and organisational-level indicators, as each captures different aspects of CSA and programme effectiveness.

Despite this, an important gap persists across the broader literature reviewed in this study. Although the included studies report a wide range of measurable indicators, only a small number explicitly frame their measurement outputs as formal KPIs or organisational metrics with defined targets and accountability structures [6, 52, 7, 23]. Most studies instead report awareness levels, scores, or assessment outputs without formally positioning them as strategic performance indicators. This reflects the observation by Jacobs et al. [7] that organisations frequently struggle to evaluate programme effectiveness beyond compliance-oriented indicators such as training completion rates. Overall, the findings suggest that while CSA is widely measured within organisational environments, the formal integration of these measurements into strategic KPIs with defined benchmarks and accountability structures remains largely absent from the existing literature, representing a gap between current measurement practice and strategic performance management [4, 7, 6]. The indicators identified and categorised in this review may serve as foundational components for the development of more formalised and standardised cybersecurity awareness KPI frameworks in future research.

The uneven attention given to different CSA dimensions further reflects the broader measurement patterns identified throughout the review. The dimensions most frequently addressed in the literature largely correspond to the standard focus areas embedded within widely used instruments such as HAIS-Q, suggesting that existing measurement practices are shaped more by the structure of dominant assessment tools than by organisation-specific security priorities. Consequently, emerging or context-dependent areas, such as cloud service use, receive comparatively limited attention despite their increasing organisational relevance. At the same time, the underlying constructs assessed across these dimensions remain predominantly knowledge, attitude, and self-reported behaviour, while direct behavioural observation appears only in a limited number of phishing-related and incident-reporting contexts. Together, these patterns reinforce the broader tendency within CSA measurement research to prioritise structured and easily quantifiable forms of assessment over direct observation of everyday security behaviour.

The most significant gap identified by this review concerns the underrepresentation of SME contexts. Only five of the 52 included studies were conducted explicitly within SME settings, despite SMEs representing the majority of enterprises in most economies [4]. In contrast, many of the remaining studies were conducted within larger organisational environments, included broader employee populations, or did not clearly specify organisational size, limiting the extent to which the broader CSA measurement literature can be directly generalised to SME contexts. The dominant measurement approaches identified in this review, particularly HAIS-Q and phishing simulation-based assessment, often assume levels of organisational capacity and technical infrastructure that may not be available within many SME environments [4, 17]. Although the SME-focused studies identified in this review

demonstrate that lightweight and context-specific approaches such as CHARM and DSAPE are feasible within smaller organisations, these approaches have not been widely adopted or independently validated [23, 6]. In addition, despite the extensive use of HAIS-Q across organisational CSA studies, the instrument has not been specifically adapted or validated for SME contexts [12, 19]. Consequently, the broader CSA measurement evidence base cannot be assumed to transfer directly to SME environments without further contextual adaptation and validation.

5.1. Limitations

While the review followed a structured and systematic approach, certain methodological considerations should be acknowledged when interpreting the findings. First, although the review employed a comprehensive search strategy across four major academic databases, relevant studies may still have been omitted due to variations in terminology and keyword usage across the literature. For example, during the review process, a study focusing on phishing simulation evaluation was identified outside the primary search results, suggesting that some studies may not explicitly use broader CSA-related terminology and therefore may not be captured through predefined search strings.

In addition, the review focused exclusively on peer-reviewed academic literature and did not include grey literature sources such as industry reports, organisational publications, or unpublished studies. As a result, certain practical cybersecurity awareness measurement approaches currently used within organisational environments may not be fully represented within the findings. The thematic categorisation process also involved analytical interpretation when grouping indicators, measurement approaches, and CSA dimensions across studies. Although repeated review and comparative analysis were conducted throughout the categorisation process, alternative grouping structures may also be possible.

6. Conclusions

This review examined how cybersecurity awareness is measured in organisational settings, based on a systematic analysis of 52 studies published between 2010 and 2025. The aim was to bring together the indicators, measurement approaches, and dimensions used across the literature, since earlier work in this area has been scattered and inconsistent in terminology.

The findings show that organisations rely on four broad types of indicators: self-reported, knowledge-based, behavioural, and organisational-based. Self-reported indicators were by far the most common, largely because the KAB model and the HAIS-Q questionnaire dominate the field. Behavioural indicators such as phishing click rates and reporting rates were used less often, but they offered useful evidence of what employees actually do rather than what they say they do. Knowledge-based and organisational-based indicators appeared even less frequently, which points to an uneven distribution of measurement focus.

The review also identified ten recurring CSA dimensions. Email use and phishing susceptibility was the most frequently measured area, followed by password management, information handling, and incident reporting. Dimensions like cloud services and workstation security received much less

attention. Most of these areas were assessed through knowledge, attitude, and self-reported behaviour, which again reflects the strong reliance on questionnaire-based methods.

A clear gap emerged around SME contexts. Only five of the 52 studies focused explicitly on small or medium-sized enterprises. The rest were conducted in larger organisations, government agencies, banks, or healthcare institutions. Given that SMEs face similar threats but usually work with fewer resources, this absence is significant. Tools such as CHARM and DSAPE show that lightweight, SME-friendly approaches are feasible, but the area remains underexplored.

The contribution of this study is analytical rather than prescriptive. It does not propose a new framework or instrument. Instead, it offers a structured synthesis of current practices that can serve as a foundation for future research and as a reference for organisations trying to make sense of existing measurement options.

6.1. Future Work

Several future research directions emerge from the findings of this review. The most significant concerns the limited attention given to SME and MSME contexts within existing CSA measurement research. Further investigation is needed to determine whether widely used instruments such as HAIS-Q can be effectively adapted for smaller organisational environments, or whether lightweight approaches such as CHARM and DSAPE provide more suitable alternatives for SME settings.

A second direction concerns the gap between self-reported and observed behaviour. Given the strong reliance on questionnaire-based assessment approaches across the reviewed studies, greater emphasis is needed on integrating self-reported measures with behavioural indicators derived from phishing simulations, incident logs, and organisational system records. Such approaches may provide a more comprehensive understanding of how reported awareness aligns with actual security behaviour in practice.

The underrepresented dimensions identified in this review also require further attention. Cloud service use and workstation security were addressed only rarely within the reviewed studies, despite their increasing relevance within modern organisational environments. Greater attention is therefore needed toward assessment approaches and indicators that more effectively address these dimensions within CSA measurement research.

An additional area for investigation concerns how CSA measurement outputs can be integrated into organisational KPI frameworks with defined targets, benchmarking mechanisms, and accountability structures. Further research documenting how organisations currently measure and operationalise CSA in practice may also support the development of more practically applicable measurement frameworks. The indicators identified and categorised in this review may provide a foundation for developing more structured and comparable approaches to organisational CSA measurement.

References

- [1] V. Zimmermann, K. Renaud, Moving from a ‘human-as-problem’ to a ‘human-as-solution’ cyber-security mindset, *International Journal of Human-Computer Studies* 131 (2019) 169–187.

- [2] M. Bada, A. M. Sasse, J. R. Nurse, Cyber security awareness campaigns: Why do they fail to change behaviour?, arXiv preprint arXiv:1901.02672 (2019).
- [3] M. Alshaikh, S. B. Maynard, A. Ahmad, S. Chang, An exploratory study of current information security training and awareness practices in organizations (2018).
- [4] S. Chaudhary, V. Gkioulos, S. Katsikas, Developing metrics to assess the effectiveness of cybersecurity awareness program, *Journal of Cybersecurity* 8 (2022) tyac006.
- [5] H. A. Kruger, W. D. Kearney, A prototype for assessing information security awareness, *Computers & security* 25 (2006) 289–296.
- [6] C. Manifavas, K. Fysarakis, K. Rantos, G. Hatzivasilis, Dsape–dynamic security awareness program evaluation, in: *International Conference on Human Aspects of Information Security, Privacy, and Trust*, Springer, 2014, pp. 258–269.
- [7] J. L. Jacobs, J. M. Haney, S. M. Furman, Measuring the effectiveness of us government security awareness programs: a mixed-methods study, in: *International Conference on Human-Computer Interaction*, Springer, 2023, pp. 14–33.
- [8] J. Haney, J. Jacobs, S. Furman, F. Barrientos, Approaches and challenges of federal cybersecurity awareness programs, *NIST Reports* (2022).
- [9] J. Kävrestad, M. Nohlberg, Evaluation strategies for cybersecurity training methods: a literature review, in: *International Symposium on Human Aspects of Information Security and Assurance*, Springer, 2021, pp. 102–112.
- [10] R. Rohan, D. Pal, J. Hautamäki, S. Funilkul, W. Chutimaskul, H. Thapliyal, A systematic literature review of cybersecurity scales assessing information security awareness, *Heliyon* 9 (2023).
- [11] T. Fertig, A. Schütz, About the measuring of information security awareness: a systematic literature review (2020).
- [12] S. Chaudhary, V. Gkioulos, S. Katsikas, A quest for research and knowledge gaps in cybersecurity awareness for small and medium-sized enterprises, *Computer Science Review* 50 (2023) 100592.
- [13] J. R. C. Nurse, *Cybersecurity Awareness*, Springer Berlin Heidelberg, Berlin, Heidelberg, 2019, pp. 1–4. URL: https://doi.org/10.1007/978-3-642-27739-9_1596-1. doi:10.1007/978-3-642-27739-9_1596-1.
- [14] I. M. K. Putra, D. I. Sensuse, S. Lusa, P. A. W. Putro, Information security awareness level evaluation in government institution: A case study of indonesian meteorological, climatological, and geophysical agency employees, *Calitatea* 26 (2025) 205–217.
- [15] M. Alshaikh, Developing cybersecurity culture to influence employee behavior: A practice perspective, *Computers & Security* 98 (2020) 102003.
- [16] B. Uchendu, J. R. Nurse, M. Bada, S. Furnell, Developing a cyber security culture: Current practices and future needs, *Computers & Security* 109 (2021) 102387.
- [17] M. Hudson, A. Smart, M. Bourne, Theory and practice in sme performance measurement systems, *International journal of operations & production management* 21 (2001) 1096–1115.
- [18] A. McCormac, D. Calic, K. Parsons, T. Zwaans, M. Butavicius, M. Pattinson, Test-retest reliability and internal consistency of the human aspects of information security questionnaire (hais-q) (2016).
- [19] K. Parsons, D. Calic, M. Pattinson, M. Butavicius, A. McCormac, T. Zwaans, The human aspects of information security questionnaire (hais-q): two further validation studies, *Computers & Security* 66 (2017) 40–51.
- [20] T. Stefaniuk, Training in shaping employee information security awareness, *Entrepreneurship and Sustainability Issues* 7 (2020) 1832.

- [21] B. Alkhazi, M. Alshaikh, S. Alkhezi, H. Labbaci, Assessment of the impact of information security awareness training methods on knowledge, attitude, and behavior, *IEEE access* 10 (2022) 132132–132143.
- [22] D. S. Hermawan, F. Setiadi, D. Oktaria, Measurement level of information security awareness for employees using kab model with study case at xyz agency, in: 2022 1st International Conference on Software Engineering and Information Technology (ICoSEIT), IEEE, 2022, pp. 174–179.
- [23] A. Ibrahim, S. U. Rehman, P. A. Williams, A. Jolfaei, Introducing charm: a practical cyber hygiene awareness rating metric for msme, *IEEE Transactions on Consumer Electronics* (2025).
- [24] A. I. M. Alluhayb, S. U. Rehman, N. Janjua, Cyber hygiene awareness and practices among saudi micro and small enterprises, in: 2025 IEEE International Conference on E-Business Engineering (ICEBE), IEEE, 2025, pp. 292–297.
- [25] S. Keele, et al., Guidelines for performing systematic literature reviews in software engineering, Technical Report, Technical report, ver. 2.3 ebse technical report. ebse, 2007.
- [26] B. Kitchenham, O. P. Brereton, D. Budgen, M. Turner, J. Bailey, S. Linkman, Systematic literature reviews in software engineering—a systematic literature review, *Information and software technology* 51 (2009) 7–15.
- [27] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan, et al., The prisma 2020 statement: an updated guideline for reporting systematic reviews, *bmj* 372 (2021).
- [28] D. S. Cruzes, T. Dyba, Recommended steps for thematic synthesis in software engineering, in: 2011 international symposium on empirical software engineering and measurement, IEEE, 2011, pp. 275–284.
- [29] A. McCormac, D. Calic, M. Butavicius, K. Parsons, T. Zwaans, M. Pattinson, et al., A reliable measure of information security awareness and the identification of bias in responses, *Australasian Journal of Information Systems* 21 (2017).
- [30] A. Prasetyo, R. F. Aji, W. S. Wibowo, Assessing information security awareness among indonesian government employees: A case study of the meteorology, climatology, and geophysics agency., *Journal of Information Systems Engineering & Business Intelligence* 11 (2025).
- [31] Y. Normandia, L. Kumaralalita, A. N. Hidayanto, W. S. Nugroho, M. R. Shihab, Measurement of employee information security awareness using analytic hierarchy process (ahp): A case study of foreign affairs ministry, in: 2018 International Conference on Computing, Engineering, and Design (ICCED), IEEE, 2018, pp. 52–56.
- [32] M. G. Ikhsan, K. Ramli, Measuring the information security awareness level of government employees through phishing assessment, in: 2019 34th international technical conference on circuits/systems, computers and communications (ITC-CSCC), IEEE, 2019, pp. 1–4.
- [33] A. Kusumawati, Information security awareness: study on a government agency, in: 2018 International Conference on Sustainable Information Engineering and Technology (SIET), IEEE, 2018, pp. 224–229.
- [34] E. A. Puspitaningrum, F. T. Devani, V. Q. Putri, A. N. Hidayanto, I. C. Hapsari, et al., Measurement of employee information security awareness: Case study at a government institution, in: 2018 Third International Conference on Informatics and Computing (ICIC), IEEE, 2018, pp. 1–6.
- [35] V. A. Effendy, Y. Ruldeviyani, M. M. Rifa'i, V. A. Rahmatika, W. Nur'Aini, Y. P. Sagala, Measurement of employee information security awareness on data security: A case study at xyz polytechnic, in: 2022 1st International Conference on Information System & Information Technology (ICISIT), IEEE, 2022, pp. 272–276.

- [36] D. D. H. Wahyudiwan, Y. G. Sucahyo, A. Gandhi, Information security awareness level measurement for employee: Case study at ministry of research, technology, and higher education, in: 2017 3rd international conference on science in information technology (ICSITech), IEEE, 2017, pp. 654–658.
- [37] A. Tick, N. Szabó-Harka, Analysis of information security in a corporate environment—a human perspective, in: 2024 IEEE 22nd World Symposium on Applied Machine Intelligence and Informatics (SAMI), IEEE, 2024, pp. 000469–000474.
- [38] A. Cindana, Y. Ruldeviyani, Measuring information security awareness on employee using hais-q: Case study at xyz firm, in: 2018 International Conference on Advanced Computer Science and Information Systems (ICACSYS), IEEE, 2018, pp. 289–294.
- [39] A. Zulfia, R. Adawiyah, A. N. Hidayanto, N. F. A. Budi, Measurement of employee information security awareness using the human aspects of information security questionnaire (hais-q): Case study at pt. pqs, in: 2019 5th International Conference on Computing Engineering and Design (ICCED), IEEE, 2019, pp. 1–5.
- [40] P. M. Musuva, et al., Determining the efficacy of cybersecurity awareness programs on enhancing wifi security behaviour, in: 2024 IST-Africa Conference (IST-Africa), IEEE, 2024, pp. 1–8.
- [41] A. Alqudhaibi, M. Albarrak, S. Jagtap, N. Williams, K. Salonitis, Securing industry 4.0: Assessing cybersecurity challenges and proposing strategies for manufacturing management, *Cyber Security and Applications* 3 (2025) 100067.
- [42] H. Effendi, S. Sumpeno, A. Affandi, The effect of programmer information security awareness on the results of vulnerability assessments in achieving secure applications, in: 2022 2nd International Conference on Information Technology and Education (ICIT&E), IEEE, 2022, pp. 280–286.
- [43] S. Abulhaija, S. Hattab, A. Qusef, Cyber security awareness, knowledge and behavior in the banking sector in jordan, in: 2022 13th International Conference on Information and Communication Systems (ICICS), IEEE, 2022, pp. 48–53.
- [44] N. Innab, H. Al-Rashoud, R. Al-Mahawes, W. Al-Shehri, Evaluation of the effective anti-phishing awareness and training in governmental and private organizations in riyadh, in: 2018 21st saudi computer society national computer conference (NCC), IEEE, 2018, pp. 1–5.
- [45] K. Alasgarova, S. Ramazanov, Development of strategies for enhancing cybersecurity and digital trust in azerbaijan’s digital landscape, *Technology audit and production reserves* 6 (2025) 39–56.
- [46] F. J. G. Arellano, Í. D. Barraza, A. F. Bustos, C. P. Soto, V. F. Fonseca, R. Martínez-Peláez, Examining cybersecurity culture in leon city organizations: Insights from 2022, *Ingeniare: Revista Chilena de Ingeniería* 32 (2024) 1–16.
- [47] W. Volz, Design and evaluation of a security awareness escape room, in: *International Conference on Human-Computer Interaction*, Springer, 2025, pp. 156–172.
- [48] N. Trianasari, P. K. Sari, A. Prasetyo, Intraclass correlation coefficient: Application for validation of health information security and privacy awareness scale, in: 2024 7th International Seminar on Research of Information Technology and Intelligent Systems (ISRITI), IEEE, 2024, pp. 397–402.
- [49] F. Abu-Amara, R. A. Hosani, H. A. Tamimi, B. A. Hamdi, Spreading cybersecurity awareness via gamification: zero-day game, *International Journal of Information Technology* 16 (2024) 2945–2953.
- [50] F. Gioulekas, E. Stamatiadis, A. Tzikas, K. Gounaris, A. Georgiadou, A. Michalitsi-Psarrou, G. Doukas, M. Kontoulis, Y. Nikoloudakis, S. Marin, et al., A cybersecurity culture survey targeting healthcare critical infrastructures, in: *Healthcare*, volume 10, MDPI, 2022, p. 327.
- [51] E. Kritzinger, A. Da Veiga, W. van Staden, Measuring organizational information security awareness in south africa, *Information Security Journal: A Global Perspective* 32 (2023) 120–133.

- [52] H. Ernita, Y. Ruldeviyani, D. N. Maftuhah, R. Mulyadi, et al., Strategy to improve employee security awareness at information technology directorate bank xyz, *Jurnal RESTI (Rekayasa Sistem dan Teknologi Informasi)* 6 (2022) 577–584.
- [53] M. S. Mahardika, A. N. Hidayanto, P. A. Paramartha, L. D. Ompusunggu, R. Mahdalina, F. Affan, Measurement of employee awareness levels for information security at the center of analysis and information services judicial commission republic of indonesia, *Advances in Science, Technology and Engineering Systems* 5 (2020) 501–509.
- [54] E. Albrechtsen, J. Hovden, Improving information security awareness and behaviour through dialogue, participation and collective reflection. an intervention study, *Computers & Security* 29 (2010) 432–445.
- [55] A. Georgiadou, A. Michalitsi-Psarrou, D. Askounis, Evaluating the cyber-security culture of the epe sector: Applying a cyber-security culture framework to assess the epe sector's resilience and readiness, in: *Proceedings of the 17th International Conference on Availability, Reliability and Security*, 2022, pp. 1–10.
- [56] J. Hagen, E. Albrechtsen, S. Ole Johnsen, The long-term effects of information security e-learning on organizational learning, *Information Management & Computer Security* 19 (2011) 140–154.
- [57] M. R. Pattinson, M. A. Butavicius, K. Parsons, A. McCormac, D. Calic, C. Jerram, The information security awareness of bank employees., in: *HAISA*, 2016, pp. 189–198.
- [58] A. McCormac, T. Zwaans, K. Parsons, D. Calic, M. Butavicius, M. Pattinson, Individual differences and information security awareness, *Computers in Human Behavior* 69 (2017) 151–156.
- [59] L. Hadlington, M. Popovac, H. Janicke, I. Yevseyeva, K. Jones, Exploring the role of work identity and work locus of control in information security awareness, *Computers & Security* 81 (2019) 41–48.
- [60] T. Gundu, S. Flowerday, K. Renaud, Deliver security awareness training, then repeat:{Deliver; Measure Efficacy}, in: *2019 conference on information communications technology and society (ICTAS)*, IEEE, 2019, pp. 1–6.
- [61] N. Tanrıverdi, B. Metin, Evaluation of it security perception, in: *Twenty-third Americas Conference on Information Systems* 3p, 2017.
- [62] N. Lungu, B. B. Dash, U. C. De, S. Rout, T. H. Sardar, S. S. Patra, Adaptive gamified cybersecurity training for enhanced user engagement, in: *2025 5th International Conference on Soft Computing for Security Applications (ICSCSA)*, IEEE, 2025, pp. 124–129.
- [63] P. Mayer, C. Schwartz, M. Volkamer, On the systematic development and evaluation of password security awareness-raising materials, in: *Proceedings of the 34th Annual Computer Security Applications Conference*, 2018, pp. 733–748.
- [64] T. Hyla, L. Fabisiak, Measuring cyber security awareness within groups of medical professionals in poland (2020).
- [65] A. Georgiadou, A. Michalitsi-Psarrou, F. Gioulekas, E. Stamatiadis, A. Tzikas, K. Gounaris, G. Doukas, C. Ntanos, L. Landeiro Ribeiro, D. Askounis, Hospitals' cybersecurity culture during the covid-19 crisis, in: *Healthcare*, volume 9, MDPI, 2021, p. 1335.
- [66] G. Ho, A. Mirian, E. Luo, K. Tong, E. Lee, L. Liu, C. A. Longhurst, C. Dameff, S. Savage, G. M. Voelker, Understanding the efficacy of phishing training in practice, in: *2025 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2025, pp. 37–54.
- [67] Q.-T. Tran, D.-P. Nguyen, T.-V. Nguyen, D.-M. Dinh, H.-L. Vu, A.-N. Nguyen, T.-A. Hoang, T.-S. Ngo, Enhancing cybersecurity awareness among users and employees: A practical approach, in: *2025 Joint International Conference on Digital Arts, Media and Technology with ECTI Northern*

Section Conference on Electrical, Electronics, Computer and Telecommunications Engineering (ECTI DAMT & NCON), IEEE, 2025, pp. 617–622.

- [68] S. Prasanna, V. Mariappan, K. A. Ahmed, V. Damodharan, The security environment in indian commercial banks: an employee’s information security behaviour perspective, *International Journal of Business Innovation and Research* 34 (2024) 277–298.
- [69] C. Z. Oroni, F. Xianping, Structural evaluation of management capability and the mediation role of cybersecurity awareness towards enterprise performance, *Journal of Data, Information and Management* 5 (2023) 345–361.
- [70] A. N. Hidayanto, et al., Measurement of employee information security awareness: a case study at an indonesian correctional institution, in: *2022 1st International Conference on Information System & Information Technology (ICISIT)*, IEEE, 2022, pp. 318–323.
- [71] M. T. Siponen, A conceptual foundation for organizational information security awareness, *Information management & computer security* 8 (2000) 31–41.
- [72] R. Wash, E. Rader, C. Fennell, Can people self-report security accurately? agreement between self-report and behavioral measures, in: *Proceedings of the 2017 CHI conference on human factors in computing systems*, 2017, pp. 2228–2232.
- [73] D. Lain, K. Kostiainen, S. Čapkun, Phishing in organizations: Findings from a large-scale and long-term study, in: *2022 IEEE Symposium on Security and Privacy (SP)*, 2022, pp. 842–859. doi:10.1109/SP46214.2022.9833766.
- [74] M. Steves, K. Greene, M. Theofanos, Categorizing human phishing difficulty: a phish scale, *Journal of Cybersecurity* 6 (2020) tyaa009.

A. Overview of Included Studies

Table A1: Overview of Cybersecurity Awareness Measurement Instruments, Methods, and Key Indicators Across Included Studies

Reference(s)	Framework / Tool (Measurement Focus and Key Indicators)	Method
[18, 19, 21, 22, 29, 35, 36, 38, 39, 47, 53, 57, 58, 59]	HAIS-Q / KAB Model (7 focus areas: password management, email use, internet use, social media, mobile devices, information handling, incident reporting)	Questionnaire (Likert scale)
[14]	KAB Model / Adapted from HAIS-Q (8 focus areas: password management, email use, internet use, social media, mobile devices, information handling, incident reporting, Use of cloud services)	Questionnaire (Likert scale)
[30]	KAB Model / Adapted from HAIS-Q (9 focus areas: password management, email use, internet use, social media, mobile devices, information handling, incident reporting, Computer Device Security, Information Security Policies)	Questionnaire (Likert scale)

Reference(s)	Framework / Tool (Measurement Focus and Key Indicators)	Method
[52]	KAB / HAIS-Q + Phishing Simulation (clicked link, submitted data, email reported)	Questionnaire + phishing simulation
[34]	KAB / HAIS-Q / KAMI index (8 focus areas: password management, email usage, use of the internet, use of social media, mobile device, information handling, incident reporting, management of information assets)	Questionnaire (Likert scale)
[70]	KAB / HAIS-Q / KAMI index (9 focus areas: password management, email usage, internet usage, social media usage, mobile device, information handling, incident reporting, information security policy, workstation security)	Questionnaire (Likert scale)
[32]	HAIS-Q (knowledge measured across 7 focus areas) + Phishing Simulation (Email Opened, Clicked Link, Submitted Data)	Phishing simulation + questionnaire (Likert scale)
[31, 33, 51]	KAB Model (Custom / Adapted) (Knowledge, Attitude, Behaviour with organisation-specific focus areas)	Questionnaire (Likert scale)
[42]	KAB / COBIT 5	Questionnaire (Likert scale)
[60]	ASTuTE (Delivery (C1): pass and fail rate, frequency of training, number of employees; Awareness (C2): attitude, knowledge, behavioural intention; Behaviour (C3): observation, incident logbook, antivirus statistics)	Questionnaire/survey tests, observations, and the incident logbook
[67]	Phishing Simulation (Click rate, credential submission rate, report rate, repeat failure rate)	Simulated phishing campaigns
[66]	Phishing Simulation (Phishing click rate, credential submission rate, report rate, knowledge retention rate, Training engagement (time spent), Training completion rate)	Experiment / Simulation
[49]	Custom Survey (Questionnaire items - no established named framework) + Phishing Simulation	Survey + phishing simulation
[23, 24]	CHARM (Cyber Hygiene Awareness Rating Metric – 5 domains: Social Engineering, Passwords and Multi-Factor Authentication (MFA), Backups, Updates, and Privacy)	Questionnaire (Behaviour-based survey)
[6]	DSAPE (Dynamic Security Awareness Program Evaluation – 18 quantitative metrics across 12 categories)	simulation

Reference(s)	Framework / Tool (Measurement Focus and Key Indicators)	Method
[62]	Gamified Cybersecurity Training (incident reporting rates, policy compliance, training completion rates, session duration, return frequency, knowledge retention)	Experiment (Gamified training)
[20, 37, 40, 41, 43, 44, 45, 46, 50, 54, 56, 61, 68, 69]	Custom Survey (Organisation-specific questionnaire items - no established named framework)	Questionnaire / Survey
[55]	Security Behaviour Analysis (SBA) Tool / Cyber-Security Culture Framework (individual level attitude, awareness, behaviour and competence are measured)	Questionnaire + phishing simulation from SBA tool
[48]	Health Care-specific ISA Scale (Device protection, password management, proactive awareness, information handling)	Questionnaire (5-point scale ranging from “never” to “always”)
[64]	Custom Questionnaire (Cybersecurity knowledge and skills + basic cyberattack scenarios)	Multiple Choice Questions
[63]	Scenario-based Knowledge Assessment (Password security scenarios - secure vs. insecure behaviour judgement and password security rating)	Experiment (Pre/Post assessment)
[65]	Custom survey + phishing quiz (phishing email identification)	Questionnaire + phishing identification quiz
[7]	Survey (Documents various organisations evaluation of the effectiveness of security awareness programs using: completion rate, phishing click rate, audit reports, incident reporting rate, simulated phishing reporting rate, etc.)	Mixed methods (Focus groups + Survey)